

VULNERABILITY ASSESSMENT REPORT

Web Application Security Evaluation

Target: <https://example.com>

Date : 2026-05-21

2

HIGH SEVERITY

3

MEDIUM SEVERITY

2

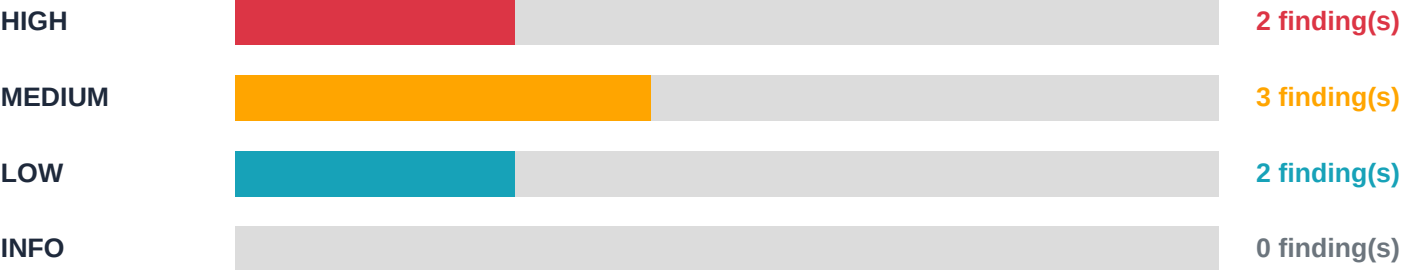
LOW SEVERITY

EXECUTIVE SUMMARY

This report presents the results of an automated vulnerability assessment conducted against <https://example.com> on 2026-05-21. A total of 7 security findings were identified across High, Medium, and Low severity levels. Each finding includes a plain-language description of the risk, supporting evidence, and actionable remediation guidance.

Disclaimer: This assessment was conducted for educational purposes as part of the Future Interns Cyber Security Internship programme. Results reflect automated checks and should be supplemented with manual testing for production use.

RISK OVERVIEW



FINDINGS INDEX

#	Vulnerability	Risk Level
1	SSL Certificate Expiring Soon	MEDIUM
2	Missing Security Header: Strict-Transport-Security	HIGH
3	Missing Security Header: Content-Security-Policy	HIGH
4	Missing Security Header: X-Content-Type-Options	MEDIUM
5	Missing Security Header: X-Frame-Options	MEDIUM
6	Missing Security Header: Referrer-Policy	LOW
7	Missing Security Header: Permissions-Policy	LOW

FINDING 01 | MEDIUM SEVERITY - SSL Certificate Expiring Soon

DESCRIPTION

The SSL certificate for example.com expires in 15 days. When a certificate expires, all browsers will block access and display a security warning, causing complete loss of user trust and site availability.

EVIDENCE / OBSERVATION

Expiry: Jun 5 00:00:00 2026 GMT (15 days remaining)

REMEDIATION

Renew the SSL certificate immediately via your Certificate Authority (e.g., Let's Encrypt auto-renew, DigiCert). Set up automated certificate renewal to prevent future expiry.

RISK: MEDIUM

FINDING 02 | HIGH SEVERITY - Missing Security Header: Strict-Transport-Security

DESCRIPTION

The HSTS header is not set. Without HSTS, browsers may connect over plain HTTP before being redirected, exposing users to SSL stripping attacks where a man-in-the-middle downgrades the connection to unencrypted HTTP.

EVIDENCE / OBSERVATION

Header 'strict-transport-security' not found in HTTP response

REMEDIATION

Add: Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

RISK: HIGH

FINDING 03 | HIGH SEVERITY - Missing Security Header: Content-Security-Policy

DESCRIPTION

No Content-Security-Policy (CSP) header is present. CSP prevents cross-site scripting (XSS) by specifying which sources of content are trusted. Without it, injected scripts from any domain can execute in the browser.

EVIDENCE / OBSERVATION

Header 'content-security-policy' not found in HTTP response

REMEDIATION

Define a strict CSP header. Start with: Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline';

RISK: HIGH

FINDING 04 | MEDIUM SEVERITY - Missing Security Header: X-Content-Type-Options

DESCRIPTION

The X-Content-Type-Options: nosniff header is absent. Without this header, older browsers may 'MIME-sniff' responses and execute them as a different content type (e.g., treating a text file as JavaScript).

EVIDENCE / OBSERVATION

Header 'x-content-type-options' not found in HTTP response

REMEDIATION

Add: X-Content-Type-Options: nosniff to all server responses.

RISK: MEDIUM

FINDING 05 | MEDIUM SEVERITY - Missing Security Header: X-Frame-Options

DESCRIPTION

The X-Frame-Options header is missing. This makes the site vulnerable to clickjacking attacks, where an attacker embeds the site in an invisible iframe to trick users into clicking on hidden buttons or links.

EVIDENCE / OBSERVATION

Header 'x-frame-options' not found in HTTP response

REMEDIATION

Add: X-Frame-Options: DENY (or SAMEORIGIN if you need iframe embedding from same domain).

RISK: MEDIUM

FINDING 06 | LOW SEVERITY - Missing Security Header: Referrer-Policy

DESCRIPTION

No Referrer-Policy header is set. Without this, the full URL (including sensitive path and query parameters) may be sent in the Referer header when users navigate to external sites.

EVIDENCE / OBSERVATION

Header 'referrer-policy' not found in HTTP response

REMEDIATION

Add: Referrer-Policy: strict-origin-when-cross-origin

RISK: LOW

FINDING 07 | LOW SEVERITY - Missing Security Header: Permissions-Policy

DESCRIPTION

No Permissions-Policy header is configured. This header controls which browser features (camera, microphone, geolocation, payment) the page is allowed to use. Without it, any injected script could access device features.

EVIDENCE / OBSERVATION

Header 'permissions-policy' not found in HTTP response

REMEDIATION

Add: Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=()

RISK: LOW

GENERAL RECOMMENDATIONS

1. Keep Software Updated

Regularly patch your CMS, plugins, server software, and dependencies.

2. Enforce HTTPS Everywhere

Use HTTPS with a valid certificate. Redirect HTTP to HTTPS. Enable HSTS.

3. Implement All Security Headers

Configure CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy.

4. Restrict Sensitive Files

Block public access to .env, .git, config files, and backup archives.

5. Harden Cookie Configuration

Set Secure, HttpOnly, and SameSite=Strict on all authentication cookies.

6. Deploy a Web Application Firewall

Use a WAF (Cloudflare, ModSecurity) to detect and block common attacks.

7. Schedule Regular Security Audits

Periodic manual pen tests and automated scans (monthly or quarterly).

8. Security Awareness Training

Train developers on OWASP Top 10 and secure coding practices.